TECHNICAL SPEC

05

Client Update Portal Specification

Technical Architecture & Requirements

PREPARED FOR	PREPARED BY	DATE	DOCUMENT
Precision Structures Inc.	EBYG Automation — SSC Digital Services	March 19, 2026	05 of 17

Project: Precision Structures Inc. Website **Document type:** Technical Specification **Prepared by:** SSC Development Team **Date:** March 18, 2026 **Status:** Draft - Pending Client Approval

1. Overview

This document specifies a lightweight, custom-built admin portal that allows authorized Precision Structures staff to edit designated website content areas without developer assistance. The portal enforces strict boundaries: only predefined content fields are editable, while page structure, navigation, layout, and design remain locked. All changes go through a staging and approval workflow before reaching the production website.

2. User Roles

ROLE	ACCESS LEVEL	CAPABILITIES
Admin	Full	Approve/reject changes, manage users, deploy to production, view audit log, configure editable fields, rollback to previous versions
Editor	Write	Edit content in designated fields, upload images, preview changes on staging, submit changes for approval
Viewer	Read-only	View current content and pending changes, leave comments on proposed edits, cannot modify content

Role Assignment

- **Admin** accounts are held by SSC development team members only.
- **Editor** accounts are created for designated Precision Structures staff (typically 1-3 people).
- **Viewer** accounts are optional, for stakeholders who want visibility without edit access.

3. Authentication and Authorization

Authentication Method

Primary: Azure Active Directory B2C

- Industry-standard identity platform, already part of the Azure ecosystem used for hosting
- Supports email/password registration with email verification.

- Supports multi-factor authentication (MFA) if the client wants additional security.
- Handles password reset, account lockout, and session management.

Fallback (simpler alternative): Custom email/password with JWT

- If Azure AD B2C is deemed too complex or costly for the scope, implement a simpler system:
  - Email/password stored with bcrypt hashing (minimum cost factor 12).
  - JWT access tokens (15-minute expiry) with HTTP-only refresh tokens (7-day expiry).
  - Password reset via email link with time-limited token (1 hour).

Session Management

PARAMETER	VALUE
Access token lifetime	15 minutes
Refresh token lifetime	7 days
Idle session timeout	30 minutes
Maximum concurrent sessions per user	3
Session storage	HTTP-only, Secure, SameSite=Strict cookies

Authorization

- Role-based access control (RBAC) enforced on every API endpoint.
- The server validates the JWT and checks the user's role before processing any request.
- Editors cannot access admin-only endpoints (user management, production deploy, rollback).
- Viewers cannot access write endpoints.

4. Editable Content Areas

Each content area maps to a specific section of a specific page. The portal presents a focused editing interface for each area, not a general-purpose HTML editor.

4.1 Hero Section (index.html)

FIELD	TYPE	CONSTRAINTS
Headline	Plain text	Max 100 characters
Subheadline	Plain text	Max 200 characters
Background image	Image upload	JPEG or PNG, max 5MB, min 1440×600px
Call-to-action text	Plain text	Max 40 characters
Call-to-action link	URL (dropdown)	Must link to an existing page on the site

4.2 About Page Content (about.html)

FIELD	TYPE	CONSTRAINTS
Page heading	Plain text	Max 80 characters
Body text	Rich text (limited)	Bold, italic, links, line breaks only. No HTML, no embedded media. Max 2000 characters.
Team/company photo	Image upload	JPEG or PNG, max 5MB
Photo caption	Plain text	Max 120 characters

4.3 Service Descriptions (services.html)

Each service is a repeatable content block. The client can edit existing services but cannot add or remove services without admin approval.

FIELD	TYPE	CONSTRAINTS
Service name	Plain text	Max 60 characters
Description	Rich text (limited)	Bold, italic, bullet lists. Max 500 characters.
Icon/image	Image upload	JPEG, PNG, or SVG, max 2MB
Display order	Integer	Drag-and-drop reordering in the UI

4.4 Gallery Images (gallery.html)

FIELD	TYPE	CONSTRAINTS
Image	Image upload	JPEG or PNG, max 5MB, min 800×600px
Caption	Plain text	Max 150 characters
Project name	Plain text	Max 80 characters
Display order	Integer	Drag-and-drop reordering
Visible	Boolean	Toggle to show/hide without deleting

Maximum gallery items: 50.

4.5 Testimonials and Quotes

FIELD	TYPE	CONSTRAINTS
Quote text	Plain text	Max 500 characters
Attribution (name)	Plain text	Max 80 characters
Attribution (company)	Plain text	Max 80 characters, optional
Visible	Boolean	Toggle to show/hide

Maximum testimonials: 20.

4.6 Contact Information

FIELD	TYPE	CONSTRAINTS
Phone number	Phone format	US phone number, validated
Email (bids)	Email format	Validated email address
Email (general)	Email format	Validated email address
Street address	Plain text	Max 200 characters
City, State, ZIP	Plain text	Max 100 characters
Business hours	Plain text	Max 200 characters
Facebook URL	URL	Must start with https://facebook.com/
Instagram URL	URL	Must start with https://instagram.com/

5. Locked Areas (Not Editable)

The following elements are never exposed in the portal and can only be changed by the development team through the normal Git workflow:

- **Navigation structure:** Menu items, links, ordering, mobile menu behavior.
- **Page layout:** HTML structure, section ordering, grid/flex layouts.
- **CSS and visual design:** Colors, fonts, spacing, responsive breakpoints, animations.
- **Footer structure:** Footer layout, copyright text, legal links.
- **JavaScript and scripts:** Interactive features, form handling, analytics, third-party integrations.
- **Meta tags and SEO:** Page titles, meta descriptions, Open Graph tags, structured data.
- **New pages:** Adding or removing pages from the site.

6. Media Upload and Management

Upload Specifications

PARAMETER	VALUE
Accepted formats	JPEG, PNG, SVG (SVG for icons only)
Maximum file size	5 MB per file
Minimum dimensions	Varies by field (see Section 4)
Maximum dimensions	4096 × 4096 px
Auto-resize	Yes, server-side (see below)
Naming convention	Auto-generated UUID, original filename preserved in metadata

Image Processing Pipeline

On upload, the server performs the following:

1. **Validate** file type (check MIME type and magic bytes, not just extension).
2. **Strip EXIF data** to remove GPS coordinates and camera metadata.
3. **Resize** to fit maximum dimensions while preserving aspect ratio:
    - Hero images: resized to 1920px wide, JPEG quality 85.
    - Gallery images: resized to 1200px wide, JPEG quality 85.
    - Thumbnails: 400px wide, JPEG quality 80 (auto-generated).
    - Service icons: 200px wide, original format preserved.
4. **Optimize** file size using lossy compression (mozjpeg for JPEG, pngquant for PNG).
5. **Store** the processed image in Azure Blob Storage.
6. **Record** metadata in the database: original filename, dimensions, file size, upload date, uploaded by.

Azure Blob Storage Configuration

PARAMETER	VALUE
Storage account	Dedicated account for portal media
Container	`website-media`
Access tier	Hot
Redundancy	LRS (locally redundant)
CDN	Azure CDN endpoint for serving images to the website
Access control	Private container, accessed via SAS tokens or CDN

7. Versioning and History

Content Snapshots

Every edit creates a versioned snapshot of the affected content area. Snapshots are immutable once created.

Snapshot record:

```
{
  "id": "uuid",
  "content_area": "hero",
  "page": "index.html",
  "field_values": { "headline": "...", "subheadline": "...", ... },
  "created_by": "user-id",
  "created_at": "2026-03-18T14:30:00Z",
  "status": "pending|approved|rejected|published|rolled-back",
  "approved_by": "admin-user-id|null",
  "approved_at": "timestamp|null",
  "notes": "Editor's description of the change"
}
```

Version Comparison

The admin portal provides a side-by-side diff view for any two versions of a content area:

- **Text fields:** highlighted additions (green) and deletions (red).
- **Images:** thumbnail comparison, old vs. new, side by side.
- **Metadata:** timestamp, author, and status for each version.

Retention

- All snapshots are retained indefinitely.
- A future housekeeping policy may archive snapshots older than 2 years, but they will not be deleted.

8. Staging and Production Workflow

Environments

ENVIRONMENT	PURPOSE	URL
Staging	Preview changes before publishing	Staging slot URL from Azure SWA
Production	Live website	https://www.precisionstructures.com

Workflow

```
Editor makes change
    |
    v
Change saved as "pending" snapshot
    |
    v
Staging site rebuilds with pending content
    |
    v
Editor previews on staging
    |
    v
Editor clicks "Submit for Approval"
    |
    v
Admin receives notification (email + in-portal)
    |
    v
Admin reviews change (diff view + staging preview)
    |
    +---> Approve ---> Change deployed to production
    |
    +---> Reject (with comment) ---> Editor notified, can revise
```

Deployment Mechanism

When an admin approves a change:

1. The portal writes the updated content to the appropriate HTML file(s) in the Git repository (`develop` branch).
2. A Git commit is created with a standardized message: `content: update {area} on {page} (approved by {admin})`.
3. The commit triggers the Azure SWA deployment pipeline.
4. For production: the portal creates a pull request from `develop` to `master`, which the admin merges via the portal (or directly in GitHub).
5. The snapshot status is updated to "published."

9. Approval Workflow Details

Notifications

EVENT	RECIPIENT	CHANNEL
New change submitted	All admins	Email + in-portal badge
Change approved	Submitting editor	Email + in-portal
Change rejected	Submitting editor	Email + in-portal (includes rejection reason)
Change published to production	All editors, all admins	Email + in-portal
Rollback performed	All editors, all admins	Email + in-portal

Approval Rules

- An admin cannot approve their own changes (four-eyes principle). If only one admin exists, this rule is relaxed.
- Rejected changes include a required comment explaining why.
- Editors can revise and resubmit rejected changes.
- Changes that have been pending for more than 7 days trigger a reminder notification.

10. Rollback

One-Click Revert

Admins can revert any content area to any previous published version:

1. Navigate to the content area's version history.
2. Select the target version.
3. Click "Revert to This Version."
4. The portal creates a new snapshot with status "rolled-back-to" and deploys it through the standard staging/approval pipeline (or immediately to production if the admin chooses "emergency rollback").

Emergency Rollback

For urgent situations (e.g., incorrect contact information published):

- Admin clicks "Emergency Rollback" on any content area.
- The previous published version is deployed directly to production, bypassing staging review.
- An audit log entry is created noting the emergency action and reason.

Full Site Rollback

If multiple content areas need to be reverted simultaneously:

- Admin selects a date/time.
- The portal identifies the published version of every content area as of that date/time.
- All areas are reverted in a single operation.

11. Security

Transport

- All portal traffic over HTTPS (TLS 1.2 minimum).
- HTTP requests are redirected to HTTPS.
- HSTS header with 1-year max-age.

Authentication Security

- Passwords: minimum 10 characters, no maximum, bcrypt hashed.
- Account lockout: 5 failed attempts triggers a 15-minute lockout.
- Password reset: email-based, token expires in 1 hour.
- MFA: optional, TOTP-based (Google Authenticator, Microsoft Authenticator).

Authorization Security

- JWT tokens validated on every request.
- Role checked on every endpoint (not just at the UI level).
- API endpoints reject requests with missing, expired, or invalid tokens (401).
- API endpoints reject requests with insufficient role (403).

Input Validation

- All text inputs sanitized to prevent XSS (HTML entities escaped).
- Rich text fields use an allowlist of permitted HTML tags (b, i, em, strong, a, br, ul, ol, li).
- File uploads validated by MIME type and magic bytes.
- SQL injection prevented via parameterized queries (no string concatenation in queries).
- CSRF protection via SameSite cookies and anti-CSRF tokens on state-changing requests.

Audit Log

Every action is logged with:

FIELD	DESCRIPTION
Timestamp	UTC, ISO 8601 format
User ID	Who performed the action
Action	What was done (login, edit, approve, reject, rollback, upload, etc.)
Target	Which content area or resource was affected
IP address	Client IP at time of action
Details	Specifics (e.g., field changed from X to Y)

Audit logs are append-only and cannot be modified or deleted by any user, including admins. Logs are retained for a minimum of 2 years.

Rate Limiting

ENDPOINT TYPE	LIMIT
Login	5 requests per minute per IP
Content edit	30 requests per minute per user
Image upload	10 requests per minute per user
API (general)	100 requests per minute per user

12. Technical Architecture

Stack

COMPONENT	TECHNOLOGY
Frontend	React (or Svelte) single-page application
Backend API	Node.js with Express
Database	Azure Cosmos DB (or PostgreSQL on Azure)
File storage	Azure Blob Storage
CDN	Azure CDN
Hosting	Azure App Service (B1 tier or higher)
Authentication	Azure AD B2C (or custom JWT)
CI/CD	GitHub Actions

API Endpoints (Summary)

METHOD	ENDPOINT	ROLE	DESCRIPTION
POST	/api/auth/login	Public	Authenticate and receive JWT
POST	/api/auth/refresh	Authenticated	Refresh access token
POST	/api/auth/logout	Authenticated	Invalidate session
GET	/api/content/:page/:area	Editor+	Get current content for an area
PUT	/api/content/:page/:area	Editor	Update content (creates pending snapshot)
GET	/api/content/:page/:area/history	Editor+	List version history
GET	/api/content/:page/:area/diff/:v1/:v2	Editor+	Compare two versions
POST	/api/content/:page/:area/submit	Editor	Submit pending change for approval
POST	/api/content/:page/:area/approve/:id	Admin	Approve a pending change
POST	/api/content/:page/:area/reject/:id	Admin	Reject a pending change (with comment)
POST	/api/content/:page/:area/rollback/:id	Admin	Revert to a previous version
POST	/api/media/upload	Editor	Upload an image
GET	/api/media	Editor+	List uploaded media
DELETE	/api/media/:id	Admin	Remove an uploaded image
GET	/api/users	Admin	List users
POST	/api/users	Admin	Create user
PUT	/api/users/:id	Admin	Update user role or status
DELETE	/api/users/:id	Admin	Deactivate user
GET	/api/audit	Admin	Query audit log

Database Schema (Key Entities)

Users

COLUMN	TYPE	NOTES
id	UUID	Primary key
email	String	Unique, indexed
password_hash	String	bcrypt
role	Enum	admin, editor, viewer
is_active	Boolean	Soft delete
created_at	Timestamp	
last_login	Timestamp	

Content Snapshots

COLUMN	TYPE	NOTES
id	UUID	Primary key
page	String	e.g., "index.html"
area	String	e.g., "hero"
field_values	JSON	Content data
status	Enum	pending, approved, rejected, published, rolled-back
created_by	UUID	FK to Users
created_at	Timestamp	
reviewed_by	UUID	FK to Users, nullable
reviewed_at	Timestamp	Nullable
review_notes	String	Rejection reason or approval note
published_at	Timestamp	Nullable

Media

COLUMN	TYPE	NOTES
id	UUID	Primary key
original_filename	String	
blob_url	String	Azure Blob Storage URL
cdn_url	String	CDN URL
content_type	String	MIME type
file_size	Integer	Bytes
width	Integer	Pixels
height	Integer	Pixels
uploaded_by	UUID	FK to Users
uploaded_at	Timestamp	

Audit Log

COLUMN	TYPE	NOTES
id	UUID	Primary key
user_id	UUID	FK to Users
action	String	e.g., "content.edit", "media.upload"
target	String	e.g., "index.html/hero"
details	JSON	Change specifics
ip_address	String	
timestamp	Timestamp	Indexed

13. Support and Training

Documentation

The following documentation will be provided to the client:

1. **User Guide (Editor):** Step-by-step instructions for logging in, editing content, uploading images, previewing changes, and submitting for approval. Includes screenshots for every step.
2. **Quick Reference Card:** Single-page PDF with common tasks and keyboard shortcuts.
3. **FAQ:** Answers to anticipated questions (e.g., "What image sizes should I use?" "What happens if I make a mistake?" "How do I reset my password?").

Training

- One live training session (video call or in-person), 1-2 hours.
- Recorded session provided for future reference and onboarding new staff.
- Covers: login, editing text, uploading images, previewing, submitting for approval, and understanding the approval process.

Ongoing Support

CHANNEL	RESPONSE TIME
Email (support@ssc-dev.com)	Within 1 business day
Portal issue/bug	Within 4 business hours
Emergency (site down)	Within 1 hour during business hours

Maintenance

- Monthly security patches and dependency updates.
- Quarterly review of portal functionality with the client.
- SLA for uptime: 99.5% (excluding planned maintenance).

14. Implementation Timeline (Estimated)

PHASE	DURATION	DELIVERABLES
1. Design and planning	1 week	Wireframes, final field list, database schema
2. Backend development	2 weeks	API, authentication, database, media pipeline
3. Frontend development	2 weeks	Portal UI, content editors, preview integration
4. Integration and testing	1 week	End-to-end testing, staging deployment, security audit
5. Client training and launch	1 week	Documentation, training session, production deploy
Total	**7 weeks**	

15. Cost Summary

ITEM	ONE-TIME	MONTHLY
Design and development (Phases 1-4)	$4,000-8,000	-
Azure App Service (B1)	-	$15
Azure Cosmos DB (serverless)	-	$5-15
Azure Blob Storage + CDN	-	$5-10
Azure AD B2C (first 50k auth/mo free)	-	$0
Maintenance and support	-	$200-400
Total	**$4,000-8,000**	**$225-440**

These are estimates and will be refined during the design phase. The one-time cost depends on the final scope of editable content areas and the complexity of the approval workflow.

Appendix A: Content Area Map

```
index.html
  +-- hero (headline, subheadline, background image, CTA text, CTA link)
  +-- testimonials (repeatable: quote, name, company, visible)

about.html
  +-- main-content (heading, body text, photo, caption)

services.html
  +-- services (repeatable: name, description, icon, display order)

gallery.html
  +-- gallery-items (repeatable: image, caption, project name, order, visible)

resources.html
  +-- (no editable areas initially; content is largely static/structural)

contact.html
  +-- contact-info (phone, emails, address, hours, social links)
```

Appendix B: Glossary

TERM	DEFINITION
Snapshot	An immutable record of a content area's field values at a point in time
Pending	A change that has been saved but not yet submitted or approved
Staging	The preview environment where changes are visible before going live
Rollback	Reverting a content area to a previously published version
RBAC	Role-Based Access Control; permissions determined by user role
SAS Token	Shared Access Signature; a time-limited URL for accessing Azure Blob Storage
JWT	JSON Web Token; a compact, signed token used for authentication